TEK1314 KEAMANAN SIBER · KELAS A · KELOMPOK 4

Simulated SOC Engagement Mengamankan Backend Sistem IoT

Checkpoint Fase 1 → Fase 2 · Presentasi progres Minggu ke-9

Lead

Olan

koordinasi & waktu

Blue Team Defender

Anggi Permana Putra

J0404241154

Red Team Attacker

Raka Syauqi Ferdian

J0404241112

Zidan

Apa yang dinilai hari ini: kejelasan *rencana* — pemetaan tech stack, arsitektur lab, kesiapan hardening (10 kontrol, 3 kategori), dan keragaman attack plan Fase 2 — bukan eksekusi penuh.

Apa yang kami lindungi

KABITA — pencatatan berat badan & pakan kambing. Yang dijaga: backend-nya, bukan timbangannya.

Produk IoT: KABITA

- Timbangan badan & pakan kambing (load cell, RFID ear tag)
- **Backend:** Ubuntu Server + **ThingsBoard** + PostgreSQL
- Data operasional: berat (kg) & pakan (kg) per ekor per hari

Detail pemetaan: tech_stack_declaration.md

Aset yang dijaga SOC

Kerahasiaan	data sensor & akun operator
Integritas	berat & pakan tidak dapat dipalsukan
Ketersediaan	dashboard & API tetap melayani

Pencurian data

Ambil alih akun ThingsBoard / token device → data peternakan terbaca.

Pemalsuan telemetri

Publish MQTT/REST dengan token curian → berat & pakan palsu.

Gangguan layanan

SYN flood pada dashboard → operasi lapangan buta.

02 · DEKLARASI TECH STACK & REPLIKASI

Dari produk IoT asli ke Target Node replika

Satu VM target (`192.168.4.5`) memerankan seluruh backend.

KOMPONEN BACKEND	TEKNOLOGI ASLI (PRODUK IOT)	REPLIKA DI TARGET NODE	PORT
OS server	Ubuntu Server LTS 26.04	Ubuntu Server LTS 26.04 (1:1)	–
Platform IoT	**ThingsBoard CE** (UI + REST)	ThingsBoard CE · akun default dibiarkan	`8080`
API telemetri	REST `/api/v1/<token>/telemetry`	sama · token statis tanpa rotasi	`8080`
Database	PostgreSQL 16	PostgreSQL 16 · `thingsboard`	`5432`
Protokol perangkat	MQTT transport ThingsBoard	sama · tanpa TLS, token = username	`1883`
Manajemen jarak jauh	SSH key-based, non-root	OpenSSH · password auth aktif · user `iotadmin`	`22`

Mengapa Ubuntu Server

- Replika memakai ThingsBoard yang sama dengan produk KABITA (bukan tiruan)
- `ufw`, `fail2ban`, `apt` berfungsi → hardening dapat dibuktikan
- Kelemahan dipasang sengaja & terdaftar, bukan kebetulan

Batasan yang kami akui terbuka

- Tanpa sensor fisik / LoRaWAN / koneksi Mitra
- Tanpa TLS di Fase 2 — justru jadi bahan analisis Blue Team
- Tanpa timbangan/RFID fisik → telemetri dibangkitkan skrip

SUMBER: DOCS/PRESENTATION-MINGGU9/TECH_STACK_DECLARATION.MD

Topologi Attacker – Target – Monitoring

Satu segmen L2 `192.168.4.0/24` lewat switch, tanpa gateway ke internet.

Attacker Node

Kali Linux

`192.168.4.100`

Red Team · nmap, Metasploit, sqlmap, hping3

SWITCH

`192.168.4.0/24`

isolated lab · no internet

Target Node

Ubuntu Server 26.04

`192.168.4.5`

ThingsBoard :8080 · MQTT :1883 · PostgreSQL · SSH

Monitoring

Security Onion 3.2

`192.168.4.200`

Zeek + Suricata + Kibana

Tabel IP (tetap sejak Minggu 4)

HOST	IP	OS	PERAN
Target Server	`192.168.4.5`	Ubuntu Server	Blue
Attacker	`192.168.4.100`	Kali Linux	Red
Monitoring	`192.168.4.200`	Security Onion	Blue

Catatan visibilitas sensor

Sensor memakai NIC1 di Internal Network `pbl-kel4` dengan promiscuous `allow-all` — syarat agar trafik Attacker→Target terlihat. NIC2 host-only dipakai untuk membuka web UI. Trafik sensor sendiri harus dikecualikan dari rule alert.

SUMBER: DOCS/DESIGN/TOPOLOGY.PNG · IP_PLAN.MD

10 kontrol, 3 kategori — plus baseline traffic normal

Status jujur per commit Minggu 9: perintah & skema bukti siap; eksekusi dijadwalkan Minggu 10.

A · Access & Authentication — 4 kontrol

A-1	Nonaktifkan login `root` via SSH	Belum
A-2	SSH key-based, password auth off	Belum
A-3	Ganti port 22 → 2222	Belum
A-4	fail2ban, maxretry 3 / ban 600s	Belum

B · Service & Attack Surface — 3 kontrol

B-1	Matikan telnet/rsh/tftp/smtp/ircd/distccd	Belum
B-2	ufw default-deny + whitelist 80/2222/1883/3306	Belum
B-3	Patch OS + hapus kredensial default DB	Belum

C · Data & Application — 3 kontrol

C-1	Kredensial → env var, `.env` chmod 600	Belum
C-2	Prepared statement + ACL topik MQTT	Belum
C-3	Least-privilege user DB + log auth	Belum

Bukti yang disiapkan per kontrol

- **before:** config asli / `nmap` sebelum / login berhasil
- **after:** config baru / `nmap` sesudah / login ditolak
- Format: `<ID>_<before|after>_<topik>.png|txt` di `docs/blueteam/evidence/`

Baseline Fase 1 (sudah ditetapkan)

- Ping sensor→server 15 menit (RTT, jitter)
- 10× akses dashboard :8080, 1 kirim telemetri / 10 s
- Sinkronisasi NTP harian
- Artefak: `baseline_minggu9.pcap` + Zeek `conn.log`

Status per 22 Okt (nyata, bukan rencana): target hidup, baseline terekam 440 paket/41,3 s, `ufw` + `fail2ban` aktif, dashboard tetap HTTP 200. Sisa: pasang ThingsBoard (stack final KABITA) lalu 7 kontrol A/C.

SUMBER: DOCS/BLUETEAM/HARDENING_CHECKLIST.MD

05 · LIVE DEMO SINGKAT

Security Onion memantau traffic lab

Demo di layar, ±3 menit — traffic uji, bukan serangan sungguhan.

Yang ditunjukkan

1. **Alerts & Hunt** — Security Onion menerima log dari sensor
2. **Zeek conn.log** — pasangan IP Attacker ↔ Target terlihat
3. **tcpdump** di sensor — bukti paket nyata, bukan simulasi
4. **Grid / Kibana** — ringkasan trafik per host

Kalau demo gagal di kelas

- Screenshot ber-timestamp disimpan di repo sebelum sesi
- File `baseline_minggu9.pcap` dibuka ulang di Wireshark
- Fokus beralih ke penjelasan rule alert yang akan dipakai Fase 2

Prinsip Bagian III panduan: target adalah VM replika di jaringan tertutup — tidak ada pengujian ke sistem Mitra.

Perintah demo (ringkas)

```
sudo tcpdump -i eth0 -nn host 192.168.4.5 && ping -c 5 192.168.4.5
ssh iotadmin@192.168.4.5 "sudo ss -tulpn"  |  nmap -sV 192.168.4.5
# Security Onion → Hunt → query: event.dataset:conn source.ip:192.168.4.100
```

5 skenario, 4 kategori, tools sudah dikunci

Setiap skenario tertuju ke Target Node replika dan berakar pada celah hasil riset Minggu 4.

ID	KATEGORI	TEKNIK & TOOLS	TARGET / CELAH ACUAN	DETEKSI DIHARAPKAN
RT-01	Reconnaissance	Full TCP scan, service/OS fingerprint · `nmap`	`192.168.4.5 (semua port)`	Zeek Port_Scan / ET SCAN
RT-02	Exploitation	Akun default ThingsBoard + brute-force SSH · `Burp`, `Hydra`	`:8080 tenant@… · :22 iotadmin`	auth.log, log auth ThingsBoard
RT-03	Web / API	Curi token device → injeksi telemetri palsu · `Burp`, `curl`	`:8080 /api/v1/<token>/telemetry`	Rule POST /api/v1/*, anomali nilai
RT-04	Protokol IoT	MQTT spoof dengan token device · `mosquitto_pub`, MQTT Explorer	`:1883 v1/devices/me/telemetry`	Rule kustom (belum ada bawaan)
RT-05	Availability **maks. 1**	SYN flood 60 detik · `hping3`	`:8080 dashboard ThingsBoard`	ET DOS, Zeek conn.log (S0)

Kenapa rencana ini sah

Semua tools disebut sejak awal (bukan saat eksekusi), tiap skenario punya kontrol mitigasi pasangan di checklist — jadi Blue Team bisa siapkan deteksi lebih dulu.

Batas yang kami patuhi

Hanya `192.168.4.0/24`; DoS ≤60 detik satu service; snapshot sebelum tiap sesi; tidak menyentuh sistem Mitra.

Siklus tertutup

Tiap serangan diuji ulang setelah mitigasi. Yang dinilai bukan rumitnya serangan, tapi bukti bahwa **serangan yang sama kini gagal**.

SUMBER: DOCS/REDTEAM/ATTACK_PLAN.MD

Yang menghambat, dan langkah berikutnya

Kendala

Target generik vs tuntutan IoT	Target diganti ke Ubuntu Server; kelemahan dipasang sengaja agar skenario tetap punya sasaran
RAM laptop	3 VM tidak bisa jalan bersamaan → Security Onion dijadwalkan bergantian
Jeda UTS	Lab idle 2 minggu → perintah & skema bukti disiapkan lebih dulu
Deteksi MQTT	Tidak ada signature bawaan → harus tulis rule kustom

Pembelajaran

- Hardening harus **tiga lapis** (akses, permukaan serangan, data/aplikasi) — satu layer tidak cukup
- Tanpa baseline normal, alert tidak bisa dinilai "benar" atau "noise"
- Rencana serangan yang tool-nya jelas membuat deteksi bisa disiapkan paralel, bukan reaktif
- Celah paling berbahaya di backend IoT sering berupa **default credential & broker tanpa auth**, bukan exploit rumit

Langkah berikutnya (Fase 2)

MINGGU	TARGET	ARTEFAK
10	Snapshot, baseline pcap, eksekusi hardening prioritas, RT-01 & RT-02	`evidence/rt01, rt02, blueteam`
11	RT-03–RT-05, penutupan 5 tahap Purple Team Loop	`purple-team-log.md`
11	Vulnerability Assessment Report (dasar Incident Report Minggu 12)	`docs/reports/`

Repo publik: `github.com/anggi267/TEK1314-2026-Kel04-KelasA` · semua artefak Minggu 9 sudah di-commit sebelum sesi.